

BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO TIỂU LUẬN CUỐI KỲ

HỌC PHẦN: BẢO MẬT TRONG IOT

GIẢ MẠO THIẾT BỊ TRONG HỆ THỐNG IOT

GIẢNG VIÊN GIẢNG DẠY: HỒ NHỰT MINH

HỌ VÀ TÊN HỌC VIÊN: LÊ CHÍ TÂM

MÃ HỌC VIÊN: 231A010500

LỚP: 253INT441001

TP. HỒ CHÍ MINH - 2026

LỜI CẢM ƠN

Đề tài 28: Giả mạo thiết bị trong hệ thống IoT" là kết quả của quá trình học tập và thực nghiệm nghiêm túc của em. Để hoàn thành tốt đề tài này, bên cạnh nỗ lực cá nhân, em đã nhận được sự hỗ trợ, hướng dẫn và động viên rất lớn từ Thầy Hồ Nhựt Minh.

Lời đầu tiên, em xin gửi lời cảm ơn sâu sắc nhất đến Quý Thầy Cô khoa Công nghệ Thông tin - Trường Đại học Văn Hiến, những người đã truyền đạt kiến thức nền tảng vững chắc và định hướng tư duy chuyên môn cho em trong suốt quá trình học tập tại trường.

Đặc biệt, em xin gửi lời cảm ơn chân thành và sâu sắc nhất đến Thầy Hồ Nhựt Minh, giảng viên trực tiếp hướng dẫn đề tài. Thầy đã tận tình chỉ bảo, đưa ra những định hướng đúng đắn cũng như dành thời gian góp ý chi tiết để em có thể triển khai hệ thống mô phỏng, phương án xác thực và hoàn thiện báo cáo một cách toàn diện nhất.

Dù đã cố gắng đầu tư thời gian và tâm huyết để thực hiện đề tài một cách cẩn chu, tuy nhiên do kiến thức và kinh nghiệm thực tế của bản thân vẫn còn những giới hạn nhất định, báo cáo khó tránh khỏi những thiếu sót. Em rất mong nhận được những ý kiến đóng góp, nhận xét quý báu từ Thầy để đề tài được hoàn thiện hơn và giúp em rút ra những bài học kinh nghiệm cho chặng đường phát triển sau này.

Em xin kính chúc Thầy luôn dồi dào sức khỏe, hạnh phúc và gặt hái được nhiều thành công trong sự nghiệp trồng người cao quý!

Em xin chân thành cảm ơn!

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	<i>Giả mạo thiết bị trong hệ thống IoT</i>
Mã đề tài	<i>28</i>
Sinh viên - MSSV	<i>Lê Chí Tâm – 231A010500</i>
Repo GitHub	<u>https://github.com/lechitam1602-dot/De-tai-28-Gia-mao-thiet-bi-trong-he-thong-IoT.git</u>
Bản báo cáo	<i>231A010500_LeChiTam_DeTai28_TieuLuan_CuoiKy.docx</i> <i>231A010500_LeChiTam_DeTai28_TieuLuan_CuoiKy.pdf</i>
Sản phẩm chính	<i>Code/config/checklist/ma trận/sơ đồ/quy trình</i>
Ngày nộp	<i>03/08/2026</i>

Cam kết an toàn và học thuật

Em cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

Về việc sử dụng Trí tuệ nhân tạo (AI) trong quá trình nghiên cứu: em xin minh bạch tuyên bố rằng, trong quá trình thực hiện đề án này, tôi có sử dụng công cụ AI (ChatGPT / Google Gemini) để hỗ trợ cho các công việc: hỗ trợ viết các đoạn mã lệnh cơ bản và gợi ý cấu trúc dàn ý. Các công cụ này chỉ đóng vai trò hỗ trợ; toàn bộ ý tưởng cốt lõi, phương pháp nghiên cứu, quá trình phân tích dữ liệu và kết luận của công trình đều do em tự thực hiện và hoàn toàn chịu trách nhiệm về tính nguyên bản, tính chính xác học thuật.

- Họ tên người cam kết: Lê Chí Tâm
- Ngày cam kết: 30/07/2026
- Chữ ký: *Lê Chí Tâm*

This image shows a full page of primary-ruled paper. It features approximately 28 horizontal dotted lines spaced evenly down the page, providing a guide for handwriting practice. The paper is otherwise blank, with no margins, text, or other markings.

MỤC LỤC

LỜI CẢM ƠN.....	i
THÔNG TIN VÀ CAM KẾT NỘP BÀI.....	ii
NHẬN XÉT CỦA GIÁO VIÊN.....	iii
DANH MỤC TỪ VIẾT TẮT.....	vi
DANH MỤC HÌNH ẢNH, BẢNG.....	vii
CHƯƠNG 1. MỞ ĐẦU.....	1
1.1 Bối cảnh và lý do chọn đề tài.....	1
1.2 Phát biểu vấn đề.....	1
1.3 Mục tiêu của đề tài.....	1
1.4 Đối tượng, phạm vi và giới hạn an toàn.....	2
1.5 Sản phẩm và kết quả dự kiến.....	2
1.6 Cấu trúc báo cáo.....	2
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT.....	4
2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống.....	4
2.2. Các khái niệm liên quan.....	4
2.2.1. Internet of Things (IoT).....	4
2.2.2. Device Spoofing (Giả mạo thiết bị).....	4
2.2.3. MQTT Broker.....	5
2.2.4. HMAC (Hash-based Message Authentication Code).....	5
2.2.5. Timestamp và Replay Attack.....	5
2.2.6. Audit Log.....	5
2.2.7. Dashboard giám sát.....	5
2.2.8. Mô hình STRIDE.....	5
2.3. Nội dung cần nhấn mạnh theo đề tài.....	5
2.3.1 Mô hình cây tấn công (Attack Tree) & Luồng dữ liệu (DFD).....	5
2.3.2 Phân tích mô hình đe dọa STRIDE và Ma trận rủi ro (Risk Matrix).....	5
2.3.3 Giải pháp phòng thủ nhiều lớp (Multi-layer Defense).....	6
2.4. Các công cụ và nguồn GitHub tham khảo.....	6
2.5. Công trình hoặc giải pháp liên quan.....	6
2.5.1 Các nghiên cứu và giải pháp liên quan.....	6
2.5.2 Phần đề tài kế thừa và cải tiến.....	7
2.6. Tiểu kết Chương 2.....	7
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ.....	8
3.1. Phương pháp thực hiện.....	8
3.2. Mô hình/kiến trúc đề xuất.....	8
3.3. Môi trường, công cụ và dữ liệu.....	9
3.4. Quy trình triển khai/đánh giá.....	10
3.5. Tiêu chí đánh giá.....	10
3.5.1 Tỷ lệ nhận diện và ngăn chặn tấn công.....	10
3.5.2 Kết quả các kịch bản thử nghiệm (ACCEPT / REJECT).....	10
3.5.3 Độ trễ xử lý bổ sung.....	10
3.5.4 Số lượng sự kiện bảo mật được ghi nhận (Findings).....	10
3.5.5 Mức giảm rủi ro sau khi áp dụng giải pháp.....	11
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	12
4.1. Chuẩn bị môi trường.....	12
4.2. Thành phần sản phẩm.....	12
4.3. Kịch bản thử nghiệm.....	12
4.4. Kết quả.....	13
4.5. Script sinh báo cáo.....	15
4.6. Thảo luận & hạn chế.....	15
4.6.1 Thảo luận kết quả thu được.....	15

4.6.2 Hạn chế của đề tài	16
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	17
5.1. Tài sản và dữ liệu	17
5.2. Môi đe dọa và lỗ hổng	17
5.3. Ma trận rủi ro	18
5.3.1 Ma trận Rủi ro 5 x 5	18
5.3.2 Bảng phân loại ưu tiên xử lý rủi ro (Risk Priority Table)	18
5.4. Biện pháp giảm thiểu	19
5.5. Rủi ro còn lại	19
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN	21
6.1. Kết luận	21
6.2. Hạn chế	21
6.3. Hướng phát triển	22
TÀI LIỆU THAM KHẢO	23
PHỤ LỤC	24

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Tên đầy đủ (Tiếng Anh)	Giải thích / Nghĩa tiếng Việt
1	API	Application Programming Interface	Giao diện lập trình ứng dụng
2	DDoS	Distributed Denial of Service	Tấn công từ chối dịch vụ phân tán
3	HMAC	Hash-based Message Authentication Code	Mã xác thực thông điệp dựa trên hàm băm
4	HTTP	Hypertext Transfer Protocol	Giao thức truyền tải siêu văn bản
5	ID	Identifier / Identification	Mã định danh / Nhận dạng
6	IoT	Internet of Things	Internet kết nối mọi thứ / Mạng lưới thiết bị kết nối
7	MQTT	Message Queuing Telemetry Transport	Giao thức truyền thông điệp nhẹ cho thiết bị IoT
8	mTLS	Mutual Transport Layer Security	Bảo mật lớp truyền tải xác thực hai chiều
9	OWASP	Open Web Application Security Project	Dự án bảo mật ứng dụng web mở
10	REST	Representational State Transfer	Kiểu kiến trúc thiết kế dịch vụ web (Web Service)
11	SSL	Secure Sockets Layer	Lớp ổ cắm an toàn (giao thức bảo mật kết nối)
12	TLS	Transport Layer Security	Bảo mật lớp truyền tải (giao thức mã hóa dữ liệu)

DANH MỤC BẢNG

Bảng 1.1: Bảng sản phẩm và kết quả dự kiến.....	2
Bảng 2.1: Bảng phân tích mô hình đe dọa STRIDE và Ma trận rủi ro (Risk Matrix):.....	5
Bảng 2.2: Bảng công cụ và nguồn GitHub chính:	6
Bảng 3.1: Bảng công cụ được sử dụng trong thử nghiệm	9
Bảng 3.2: Bảng quy trình triển khai/đánh giá.....	10
Bảng 4.1: Bảng kịch bản thử nghiệm	12
Bảng 4.2: Bảng đối chiếu kết quả thực nghiệm:	15
Bảng 5.1: Bảng kiểm kê các tài sản thông tin, dịch vụ trong hệ thống IoT, kèm theo đánh giá mức độ quan trọng và yêu cầu bảo mật C/I/A (Confidentiality, Integrity, Availability):	17
Bảng 5.2: Bảng mối đe dọa và lỗ hổng.....	17
Bảng 5.3: Bảng ma trận rủi ro.....	18
Bảng 5.4: Bảng phân loại ưu tiên xử lý rủi ro (Risk Priority Table)	18

DANH MỤC HÌNH ẢNH

Hình 2.1: Mô hình kiến trúc 4 tầng của hệ thống IoT	4
Hình 3.1: Mô hình hệ thống thử nghiệm	9
Hình 4.1: Môi trường Lab Docker và các dịch vụ đang vận hành.....	12
Hình 4.2: Trạng thái container Mosquitto MQTT Broker (mosquitto-broker) đang chạy trên Docker Desktop (Port 1883).	13
Hình 4.3: Màn hình Terminal thực thi attacker_spoof.py phát các kịch bản tấn công mạo danh thiết bị (TC-02: Không có HMAC, TC-03: HMAC giả, TC-04: Replay Attack).....	13
Hình 4.4: Server Authenticator phát hiện hành vi bất thường, từ chối gói tin [REJECT] và ghi nhận các lỗi vi phạm.....	14
Hình 4.5: Minh chứng bắt gói tin giao thức MQTT trên Wireshark	14
Hình 4.6: Màn hình Terminal truyền dữ liệu cảm biến hợp lệ (TC-01)	14
Hình 4.7: Màn hình Web Dashboard truyền dữ liệu cảm biến hợp lệ (TC-01).....	15
Hình 4.8: Đoạn Output hiển thị trên Terminal (Log tự động)	15

CHƯƠNG 1. MỞ ĐẦU

1.1 Bối cảnh và lý do chọn đề tài

Trong các hệ thống Internet of Things (IoT) hiện đại như nhà thông minh (Smart Home), nông nghiệp thông minh và giám sát công nghiệp, các thiết bị đầu cuối (cảm biến, actuator) liên tục thu thập và gửi dữ liệu về trung tâm xử lý qua các giao thức như MQTT, HTTP hoặc CoAP. Tuy nhiên, do hạn chế về tài năng phần cứng và chi phí sản xuất, nhiều thiết bị IoT không được trang bị các cơ chế xác thực nguồn gốc đủ mạnh.

Tấn công Giả mạo thiết bị (Device Spoofing) xảy ra khi kẻ tấn công đánh cắp hoặc mạo danh các thông số định danh của thiết bị hợp lệ (như địa chỉ MAC, IP, Client ID, hoặc API Key) để gửi dữ liệu giả mạo hoặc thực hiện các lệnh điều khiển trái phép. Hậu quả của dạng tấn công này vô cùng nghiêm trọng, có thể dẫn đến việc sai lệch dữ liệu giám sát, kích hoạt các kịch bản điều khiển sai mục đích hoặc gây mất an toàn cho toàn bộ hạ tầng. Do đó, việc nghiên cứu cơ chế tấn công giả mạo thiết bị IoT, đồng thời xây dựng giải pháp phòng chống và giám sát thời gian thực là vô cùng cần thiết.

1.2 Phát biểu vấn đề

Trong các hệ thống Internet of Things (IoT), mỗi thiết bị đầu cuối đều phải được định danh và xác thực trước khi truyền dữ liệu đến máy chủ hoặc MQTT Broker. Tuy nhiên, trên thực tế nhiều hệ thống vẫn sử dụng các thông tin định danh tĩnh như Client ID, địa chỉ MAC, địa chỉ IP hoặc API Key để nhận diện thiết bị. Những thông tin này có thể bị thu thập thông qua kỹ thuật nghe lén lưu lượng mạng hoặc phân tích gói tin, từ đó tạo điều kiện cho kẻ tấn công giả mạo một thiết bị hợp lệ và gửi dữ liệu giả vào hệ thống.

Khi cuộc tấn công giả mạo thiết bị (Device Spoofing) xảy ra, máy chủ có thể tiếp nhận các bản tin không xuất phát từ thiết bị thật nhưng vẫn coi là hợp lệ. Điều này dẫn đến nhiều hậu quả như làm sai lệch dữ liệu cảm biến, phát sinh các lệnh điều khiển không mong muốn, ảnh hưởng đến quá trình giám sát và ra quyết định của hệ thống IoT. Trong các ứng dụng như nhà thông minh, nông nghiệp thông minh hoặc giám sát công nghiệp, các hậu quả này có thể làm giảm độ tin cậy của hệ thống và gây mất an toàn trong quá trình vận hành.

Xuất phát từ thực tế trên, đề tài tập trung xây dựng một môi trường Lab mô phỏng hệ thống IoT để thực nghiệm kịch bản tấn công Device Spoofing, đồng thời đề xuất cơ chế xác thực dựa trên HMAC kết hợp Timestamp nhằm kiểm tra tính xác thực và tính toàn vẹn của dữ liệu trước khi máy chủ tiếp nhận. Bên cạnh đó, hệ thống còn tích hợp chức năng thu thập nhật ký (Audit Log) và hiển thị cảnh báo trên Dashboard để hỗ trợ phát hiện, theo dõi và đánh giá các hành vi giả mạo thiết bị trong quá trình thử nghiệm. Kết quả của đề tài góp phần đánh giá hiệu quả của giải pháp phòng chống giả mạo thiết bị và cung cấp cơ sở tham khảo cho việc triển khai các cơ chế xác thực an toàn trong các hệ thống IoT thực tế.

1.3 Mục tiêu của đề tài

MT-01: Nghiên cứu kiến trúc của hệ thống IoT, cơ chế truyền dữ liệu giữa thiết bị cảm biến và máy chủ thông qua giao thức MQTT/HTTP, đồng thời phân tích các lỗ hổng có thể bị khai thác để thực hiện tấn công giả mạo thiết bị.

MT-02: Xây dựng môi trường Lab mô phỏng hệ thống IoT gồm các thiết bị cảm biến hợp lệ, MQTT Broker, máy chủ xác thực, Dashboard giám sát và thiết bị tấn công nhằm phục vụ quá trình thực nghiệm.

MT-03: Thiết kế và triển khai các kịch bản tấn công Device Spoofing bằng cách giả mạo thông tin định danh của thiết bị để gửi dữ liệu không hợp lệ vào hệ thống, từ đó đánh giá mức độ ảnh hưởng đối với tính toàn vẹn và độ tin cậy của dữ liệu.

MT-04: Xây dựng cơ chế xác thực dựa trên thuật toán HMAC-SHA256 kết hợp Timestamp để kiểm tra tính xác thực của từng gói tin, ngăn chặn các hành vi giả mạo.

MT-05: Tích hợp chức năng ghi nhật ký (Audit Log) và Dashboard giám sát nhằm theo dõi hoạt động của các thiết bị, phát hiện các kết nối bất thường và hỗ trợ đánh giá hiệu quả của giải pháp bảo mật.

MT-06: Đánh giá hiệu quả của giải pháp thông qua các kịch bản thử nghiệm, các tiêu chí như tỷ lệ phát hiện và ngăn chặn tấn công, độ trễ xử lý, khả năng ghi nhận nhật ký và mức độ giảm thiểu rủi ro đối với hệ thống IoT.

1.4 Đối tượng, phạm vi và giới hạn an toàn

Đối tượng nghiên cứu: Giao thức truyền tải IoT (MQTT/HTTP), các phương pháp định danh thiết bị, kỹ thuật tấn công giả mạo (MAC/IP/Client ID Spoofing) và giải pháp xác thực an toàn cho IoT.

Phạm vi triển khai:

- Môi trường thực hiện: Hoàn toàn thử nghiệm trong môi trường Local / Docker / Python Script giả lập thiết bị IoT.
- Dữ liệu sử dụng: Dữ liệu cảm biến giả lập (nhiệt độ, độ ẩm, trạng thái thiết bị) và dải IP/Client ID nội bộ trong Lab.

Giới hạn an toàn (Ethical & Scope Constraints):

- Đề tài chỉ thực hiện mô phỏng trong môi trường Lab cách ly, tuyệt đối không thực hiện tấn công hoặc can thiệp vào bất kỳ hệ thống/thiết bị IoT thực tế nào bên ngoài.
- Các công cụ và script thử nghiệm chỉ phục vụ mục đích nghiên cứu học thuật và kiểm chứng giải pháp bảo mật.

1.5 Sản phẩm và kết quả dự kiến

Bảng 1.1: Bảng sản phẩm và kết quả dự kiến

STT	Mục tiêu	Sản phẩm đầu ra dự kiến	Cách thức kiểm chứng	Chương trình bày
1	Nghiên cứu kiến trúc hệ thống IoT, cơ chế truyền dữ liệu và các lỗ hổng dẫn đến tấn công giả mạo thiết bị.	Cơ sở lý thuyết về IoT, MQTT, Device Spoofing, HMAC, STRIDE.	Phân tích ở phần cơ sở lý thuyết.	Chương 2
2	Xây dựng môi trường Lab mô phỏng hệ thống IoT phục vụ thử nghiệm.	Mô hình Lab gồm Sensor, Attacker, MQTT Broker, Server xác thực và Dashboard.	Kiểm tra khả năng kết nối, truyền nhận dữ liệu giữa các thành phần và vận hành ổn định của hệ thống.	Chương 3
3	Thiết kế và thực hiện các kịch bản tấn công giả mạo thiết bị (Device Spoofing).	Bộ mã nguồn mô phỏng thiết bị hợp lệ, thiết bị giả mạo và các kịch bản thử nghiệm.	Thực hiện các test case truyền dữ liệu hợp lệ, giả mạo thiết bị; ghi nhận kết quả bằng ảnh minh chứng và log hệ thống.	Chương 4
4	Triển khai giải pháp xác thực HMAC-SHA256 kết hợp Timestamp nhằm ngăn chặn giả mạo thiết bị.	Chương trình xác thực HMAC, cơ chế kiểm tra Timestamp và từ chối các gói tin không hợp lệ.	Kiểm tra khả năng phát hiện và chặn các gói tin giả mạo; đánh giá tỷ lệ phát hiện và độ trễ xử lý của hệ thống.	Chương 4
5	Đánh giá hiệu quả của giải pháp và đề xuất biện pháp tăng cường an toàn cho hệ thống IoT.	Audit Log, Dashboard giám sát, ma trận rủi ro, bảng đánh giá bảo mật và báo cáo kết quả thực nghiệm.	Phân tích nhật ký hệ thống, đối chiếu kết quả với các tiêu chí đánh giá và mức độ giảm thiểu rủi ro sau khi áp dụng giải pháp.	Chương 5, Chương 6

1.6. Cấu trúc báo cáo

Báo cáo có bố cục gồm 06 chương. Chương 1 trình bày bối cảnh, mục tiêu và phạm vi nghiên cứu. Chương 2 giới thiệu cơ sở lý thuyết. Chương 3 trình bày phương pháp nghiên cứu, mô hình hệ thống và môi trường triển khai. Chương 4 mô tả quá trình triển khai, các kịch

bản thử nghiệm và kết quả đạt được. Chương 5 đánh giá bảo mật, phân tích rủi ro và đề xuất biện pháp giảm thiểu. Chương 6 tổng kết kết quả nghiên cứu, nêu những hạn chế và đề xuất hướng phát triển trong tương lai.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1. Kiến trúc hoặc bối cảnh kỹ thuật của hệ thống

Hệ thống IoT bao gồm 4 tầng chính (*Hình 2.1*): Tầng thiết bị (IoT Devices), Tầng mạng (Network/Gateway), Tầng xử lý trung tâm (IoT Server/Broker), và Tầng ứng dụng (Application/Dashboard).

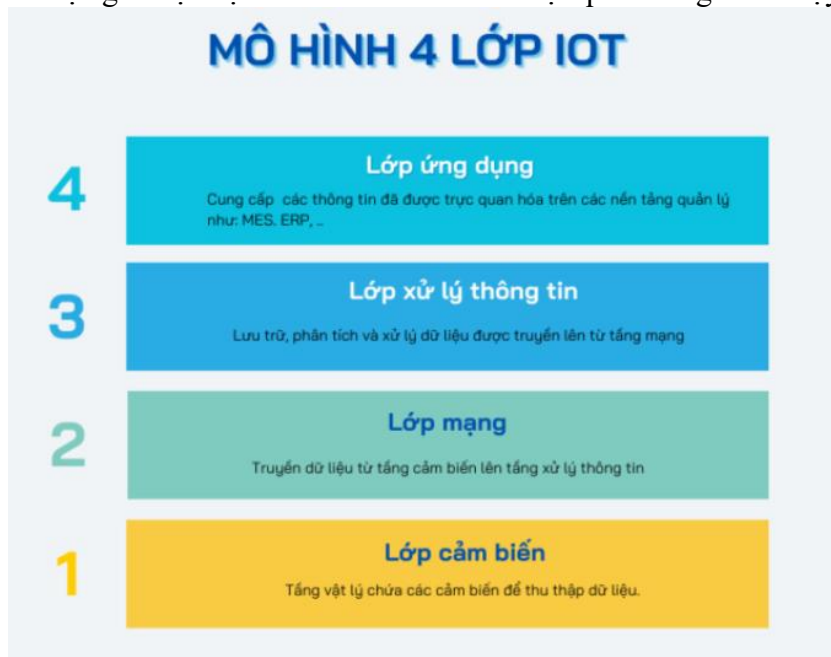
IoT Devices (Cảm biến & Thiết bị đầu cuối): Các nút cảm biến (giả lập bằng Python Script/ESP32) thực hiện thu thập dữ liệu môi trường (nhiệt độ, độ ẩm) và gửi định kỳ về Server. Mỗi thiết bị được định danh bằng các thông số: Device ID, MAC Address, IP Address và API Key/HMAC Token.

IoT Gateway / Broker: Đóng vai trò là điểm tiếp nhận trung gian. Trong mô hình này, Gateway/Server tiếp nhận các yêu cầu HTTP/MQTT request từ thiết bị, thực hiện kiểm tra định danh và chuyển tiếp dữ liệu vào cơ sở dữ liệu.

IoT Server & Database: Xử lý logic nghiệp vụ, xác thực Token/Chữ ký chữ ký số HMAC, lưu vết Log truy cập và lưu trữ dữ liệu cảm biến vào database.

Monitoring & Alert Dashboard: Hiển thị trực quan trạng thái thiết bị, lưu lượng truyền nhận và đưa ra cảnh báo thời gian thực khi phát hiện hành vi truy cập bất thường.

Ranh giới tin cậy (Trust Boundary): Ranh giới tin cậy nằm giữa Tầng thiết bị (IoT Devices) và Tầng Tiếp Nhận (IoT Gateway/Server). Môi trường mạng truyền tải (Wifi/LAN/Internet) được coi là không tin cậy (Untrusted Zone), nơi kẻ tấn công có thể nghe lén, chèn gói tin hoặc giả mạo địa chỉ IP/Client ID để vượt qua ranh giới tin cậy.



Hình 2.1: Mô hình kiến trúc 4 tầng của hệ thống IoT

2.2. Các khái niệm liên quan

2.2.1. Internet of Things (IoT)

Internet of Things (IoT) là mô hình kết nối các thiết bị vật lý thông qua mạng Internet, cho phép các thiết bị thu thập, trao đổi và xử lý dữ liệu một cách tự động. Trong hệ thống IoT, các cảm biến thu thập dữ liệu từ môi trường và truyền đến máy chủ hoặc MQTT Broker để xử lý, lưu trữ và giám sát. Đề tài sử dụng mô hình IoT làm môi trường nghiên cứu nhằm đánh giá nguy cơ giả mạo thiết bị và các giải pháp bảo vệ.

2.2.2. Device Spoofing (Giả mạo thiết bị)

Device Spoofing là hình thức tấn công mà kẻ tấn công giả mạo danh tính của một thiết bị IoT hợp lệ bằng cách sử dụng các thông tin định danh như Client ID, địa chỉ MAC, địa chỉ IP hoặc API Key. Sau khi giả mạo thành công, thiết bị giả có thể gửi dữ liệu hoặc thực hiện các yêu cầu trái phép đến máy chủ, làm ảnh hưởng đến tính chính xác và độ tin cậy của hệ thống.

2.2.3. MQTT Broker

MQTT Broker là máy chủ trung gian chịu trách nhiệm tiếp nhận, quản lý và phân phối dữ liệu giữa các thiết bị IoT. Broker thực hiện cơ chế Publish/Subscribe, giúp các thiết bị gửi và nhận dữ liệu thông qua các Topic. Trong đề tài, Eclipse Mosquitto được sử dụng làm MQTT Broker để tiếp nhận dữ liệu từ thiết bị hợp lệ và thiết bị giả mạo.

2.2.4. HMAC (Hash-based Message Authentication Code)

HMAC là cơ chế xác thực thông điệp dựa trên hàm băm và khóa bí mật dùng chung giữa thiết bị và máy chủ. Khi gửi dữ liệu, thiết bị tạo một giá trị HMAC từ nội dung bản tin và khóa bí mật. Máy chủ sẽ tính toán lại giá trị HMAC để kiểm tra tính xác thực và tính toàn vẹn của dữ liệu. Nếu hai giá trị không trùng khớp, gói tin sẽ bị từ chối.

2.2.5. Timestamp và Replay Attack

Timestamp là giá trị thời gian được gắn vào mỗi gói tin khi thiết bị gửi dữ liệu. Máy chủ sử dụng Timestamp để kiểm tra thời điểm gửi và phát hiện các gói tin đã hết hiệu lực. Cơ chế này giúp ngăn chặn Replay Attack, tức là cuộc tấn công phát lại các gói tin hợp lệ đã được ghi lại trước đó nhằm đánh lừa hệ thống.

2.2.6. Audit Log

Audit Log là cơ chế ghi lại toàn bộ các hoạt động diễn ra trong hệ thống, bao gồm thời gian kết nối, địa chỉ IP, Client ID, trạng thái xác thực và kết quả xử lý của từng yêu cầu. Nhật ký này hỗ trợ phát hiện hành vi bất thường, phục vụ công tác giám sát và điều tra khi xảy ra sự cố bảo mật.

2.2.7. Dashboard giám sát

Dashboard là giao diện trực quan dùng để theo dõi trạng thái hoạt động của hệ thống IoT. Thông qua Dashboard, người quản trị có thể quan sát dữ liệu cảm biến, các kết nối đang hoạt động và các cảnh báo khi phát hiện hành vi giả mạo hoặc truy cập bất thường.

2.2.8. Mô hình STRIDE

STRIDE là mô hình phân tích mối đe dọa do Microsoft đề xuất, gồm sáu nhóm nguy cơ: Spoofing (Giả mạo), Tampering (Sửa đổi dữ liệu), Repudiation (Chối bỏ), Information Disclosure (Lộ thông tin), Denial of Service (Từ chối dịch vụ) và Elevation of Privilege (Leo thang đặc quyền). Trong phạm vi đề tài, trọng tâm là mối đe dọa Spoofing, đồng thời xem xét các nguy cơ liên quan như Tampering và Replay Attack để đánh giá mức độ an toàn của hệ thống.

2.3. Nội dung cần nhấn mạnh theo đề tài

Đi sâu vào Mô hình tấn công giả mạo thiết bị (Device Spoofing Attack Model), điều kiện kích hoạt, tác động đến hệ thống và các giải pháp phòng thủ nhiều lớp (Defense-in-Depth).

2.3.1 Mô hình cây tấn công (Attack Tree) & Luồng dữ liệu (DFD)

Kẻ tấn công thực hiện kỹ thuật Spoofing thông qua các bước:

- Thu thập thông tin (Reconnaissance): Lắng nghe lưu lượng mạng (Packet Sniffing) bằng Wireshark để trích xuất Client_ID, IP, Topic MQTT hoặc định dạng HTTP API.
- Khởi tạo mạo danh (Spoofing Execution): Chạy script Python giả lập thiết bị mang thông tin định danh vừa thu thập được.
- Chèn dữ liệu độc hại (Data Injection): Gửi liên tục các bản tin chứa thông số sai lệch tới Server.

2.3.2 Phân tích mô hình đe dọa STRIDE và Ma trận rủi ro (Risk Matrix)

Bảng 2.1: Bảng phân tích mô hình đe dọa STRIDE và Ma trận rủi ro (Risk Matrix):

Thành phần STRIDE	Mô tả nguy cơ trong đề tài	Tác động (Impact)	Mức độ rủi ro
Spoofing (Giả mạo)	Giả mạo Device_ID/MAC Address để gửi gói tin hợp lệ về Server.	Sai lệch dữ liệu hệ thống, mất lòng tin vào thiết bị.	Rất cao (High)

Thành phần STRIDE	Mô tả nguy cơ trong đề tài	Tác động (Impact)	Mức độ rủi ro
Tampering (Sửa đổi)	Thay đổi nội dung gói tin cảm biến trên đường truyền khi không có mã hóa.	Kích hoạt kích bản báo động giả hoặc tắt thiết bị an toàn.	Cao (Medium-High)
Repudiation (Chối bỏ)	Thiết bị giả mạo gửi lệnh độc hại nhưng Server không truy vết được do thiếu Log định danh.	Khó khăn trong việc điều tra sự cố an ninh mạng.	Trung bình (Medium)

2.3.3 Giải pháp phòng thủ nhiều lớp (Multi-layer Defense)

Để triệt tiêu nguy cơ Device Spoofing, hệ thống áp dụng chiến lược phòng thủ 3 lớp:

1. Lớp Xác thực đường truyền (Transport Layer): Bắt buộc sử dụng TLS/SSL hoặc mTLS (Mutual TLS - Xác thực 2 chiều bằng Certificate) để ngăn chặn Sniffing.
2. Lớp Xác thực gói tin (Application Layer - HMAC/Dynamic Token): Mọi request gửi lên phải kèm chữ ký HMAC tạo từ Payload + Timestamp + Secret Key. Kẻ tấn công cho dù biết Client_ID nhưng không có Secret Key thì không thể tạo ra HMAC hợp lệ.
3. Lớp Giám sát & Phát hiện (Monitoring & IDS Layer): Hệ thống thu thập Log kiểm tra tần suất kết nối, sự bất thường về IP/Location hoặc kiểm tra Timestamp để chặn các cuộc tấn công phát lại (Replay Attack).

2.4. Các công cụ và nguồn GitHub tham khảo

Bảng 2.2: Bảng công cụ và nguồn GitHub chính:

STT	Nguồn	URL	Phần đã sử dụng	Truy cập
1	Eclipse Mosquitto	https://github.com/eclipse-mosquitto/mosquitto	MQTT Broker để tiếp nhận và phân phối dữ liệu giữa các thiết bị IoT	07/2026
2	Eclipse Paho MQTT Python	https://github.com/eclipse-paho/paho.mqtt.python	Thư viện Python để Publish/Subscribe dữ liệu MQTT	07/2026
3	Docker Engine	https://github.com/docker/cli	Triển khai môi trường Lab bằng container	07/2026
4	Flask	https://github.com/pallets/flask	Xây dựng Web Dashboard giám sát	07/2026
5	Wireshark	https://github.com/wireshark/wireshark	Phân tích lưu lượng mạng và kiểm chứng các gói tin	07/2026
6	Python	https://github.com/python/cpython	Phát triển chương trình mô phỏng thiết bị, máy chủ xác thực và Dashboard	07/2026

2.5. Công trình hoặc giải pháp liên quan

2.5.1 Các nghiên cứu và giải pháp liên quan

- Giải pháp 1: Xác thực dựa trên thuộc tính tĩnh (Static Identity Authentication):

Cách làm: Kiểm tra cố định địa chỉ MAC, IP, hoặc chuỗi Client_ID của thiết bị khi kết nối vào Broker/Server.

Ưu điểm: Cấu hình đơn giản, nhẹ, không tốn tài nguyên tính toán của thiết bị IoT.

Hạn chế: Rất dễ bị tấn công Spoofing. Kẻ tấn công chỉ cần dùng Wireshark bắt gói tin là có thể mạo danh hoàn toàn Client_ID hoặc MAC Address.

- Giải pháp 2: Xác thực hai chiều bằng chứng chỉ số (mTLS - Mutual TLS):

Cách làm: Cài đặt chứng chỉ **X.509** trên từng thiết bị IoT và kiểm tra xác thực hai chiều với Server.

Ưu điểm: Độ bảo mật cực cao, chống lại hoàn toàn tấn công giả mạo và nghe lén.

Hạn chế: Chi phí quản lý vòng đời chứng chỉ (PKI) phức tạp; đòi hỏi thiết bị phải có đủ dung lượng bộ nhớ và năng lực xử lý mạnh.

- Giải pháp 3: Xác thực nhẹ bằng chữ ký động HMAC (Lightweight Dynamic Authentication):

Cách làm: Thiết bị và Server chia sẻ trước một Secret Key. Mỗi bản tin gửi đi được đính kèm mã $HMAC = H(Secret_Key \parallel Payload \parallel Timestamp)$.

Ưu điểm: Đảm bảo tính toàn vẹn và chống giả mạo hiệu quả, chi phí tính toán thấp, phù hợp với hầu hết phần cứng IoT.

Hạn chế: Cần giải pháp lưu trữ an toàn khóa bí mật (Secret Key) trên phần cứng thiết bị.

2.5.2 Phần đề tài kế thừa và cải tiến

Từ việc phân tích các công trình trên, đề tài kế thừa mô hình xác thực nhẹ HMAC kết hợp kiểm tra Timestamp để chống tấn công giả mạo và Replay Attack. Đồng thời, đề tài cải tiến bằng cách tích hợp thêm lớp thu thập Log tập trung nhằm ghi nhận và tự động chặn các IP/Client ID có hành vi giả mạo liên tục trên Dashboard giám sát.

2.6. Tiểu kết Chương 2

Chương 2 đã hệ thống hóa toàn bộ cơ sở lý thuyết nền tảng cho đề tài, bao gồm kiến trúc 4 tầng của hệ thống IoT, xác định ranh giới tin cậy và phân tích mối đe dọa giả mạo thiết bị (Device Spoofing) thông qua mô hình STRIDE. Chương này cũng đã tổng hợp đầy đủ các công cụ, chuẩn bảo mật mã nguồn mở được áp dụng, đồng thời so sánh các giải pháp liên quan để chọn ra phương pháp tối ưu nhất. Các kiến thức nền này chính là cơ sở kỹ thuật trực tiếp để tiến hành Thiết kế mô hình Lab, luồng tấn công và xây dựng kịch bản thử nghiệm ở Chương 3.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Quá trình nghiên cứu và triển khai đề tài được thực hiện theo quy trình 4 bước sau:

Bước 1: Khảo sát và phân tích yêu cầu bảo mật: Nghiên cứu cơ chế hoạt động của giao thức truyền tin IoT (MQTT/HTTP) và phân tích các dạng tấn công giả mạo thiết bị (Device Spoofing). Sử dụng tài liệu chuẩn OWASP IoT Top 10 và mô hình STRIDE để xác định các lỗ hổng định danh yếu.

Bước 2: Dựng Lab mô phỏng và phát triển kịch bản: Thực hiện cài đặt môi trường ảo hóa Docker, cấu hình MQTT Broker (Eclipse Mosquitto) và viết các đoạn mã Python để giả lập hoạt động của cảm biến thật cũng như máy tấn công giả mạo. Sản phẩm đầu ra là hệ thống Lab hoàn chỉnh chạy trên môi trường thử nghiệm cách ly cùng bộ mã nguồn `sensor_legit.py` và `attacker_spoof.py`.

Bước 3: Thử nghiệm tấn công và triển khai giải pháp phòng thủ: Thực thi kịch bản giả mạo Client_ID/IP để gửi dữ liệu rác trước khi có bảo mật, sau đó áp dụng cơ chế xác thực HMAC và kiểm tra Timestamp ở phía Server để chặn các gói tin mạo danh. Sản phẩm đầu ra là mã nguồn chương trình xác thực an toàn và tệp Log ghi nhận sự kiện chặn tấn công.

Bước 4: Phân tích, đánh giá và tổng kết: Thu thập log kết nối, đo lường độ trễ xử lý gói tin và tính toán tỷ lệ phát hiện/chặn các gói tin giả mạo. Sản phẩm đầu ra là Bảng đánh giá hiệu năng, các biểu đồ đo lường và báo cáo tiểu luận hoàn chỉnh.

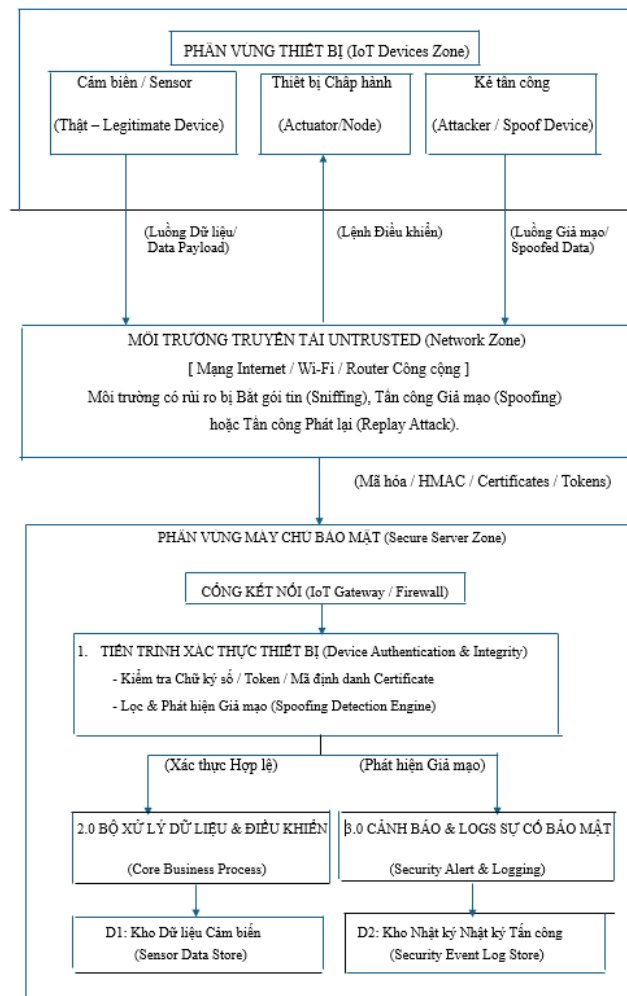
3.2. Mô hình/kiến trúc đề xuất

Mô hình hệ thống thử nghiệm được thiết kế bao gồm 3 phân vùng chính: Phân vùng Thiết bị (IoT Devices Zone), Môi trường Truyền tải Untrusted (Network Zone) và Phân vùng Máy chủ Bảo mật (Secure Server Zone). (Hình 3.1)

Mô tả thành phần:

- IoT Sensor (Legit): Nút cảm biến hợp lệ, nắm giữ Client_ID = "SENSOR_01" và khóa bí mật Secret_Key. Thiết bị này tự động đóng gói dữ liệu kèm chữ ký HMAC trước khi truyền đi.
- Attacker (Spoofers): Máy tấn công bắt gói tin trên đường truyền, thu thập Client_ID = "SENSOR_01" nhưng không có Secret Key. Attacker chạy script để mạo danh cảm biến và đẩy dữ liệu giả về Server.
- IoT Broker / Server: Máy chủ tiếp nhận gói tin. Tại đây triển khai Module Authenticator để tính toán lại HMAC và đối chiếu Timestamp. Nếu HMAC không khớp hoặc Timestamp bị lệch quá ngưỡng cho phép ($\Delta t > 5$ giây), Server lập tức hủy gói tin và ghi Log cảnh báo.
- Database & Dashboard: Lưu trữ dữ liệu hợp lệ và hiển thị danh sách các truy cập bị từ chối do giả mạo.

Giải thích lựa chọn thiết kế: Kiến trúc này đặt ranh giới tin cậy (Trust Boundary) ngay tại ngõ vào của IoT Broker/Server. Việc áp dụng xác thực HMAC ở tầng ứng dụng kết hợp kiểm tra Timestamp giúp bảo vệ hệ thống ngay cả khi truyền tải qua môi trường mạng LAN/Internet không bảo mật mà không làm quá tải phần cứng thiết bị IoT.



Hình 3.1: Mô hình hệ thống thử nghiệm

3.3. Môi trường, công cụ và dữ liệu

Bảng 3.1: Bảng công cụ được sử dụng trong thử nghiệm

Loại	Tên phần mềm	Phiên bản	Vai trò trong Lab
Hệ điều hành	Windows 11	22.04 LTS	Môi trường ảo hóa host toàn bộ hệ thống Server và các Container giả lập.
Phần mềm	Eclipse Mosquitto	2.0.18	Dùng làm MQTT Broker trung gian tiếp nhận bản tin từ cảm biến và kẻ tấn công.
Nền tảng	Python	3.11.x	Ngôn ngữ chính để viết script mô phỏng cảm biến, mã nguồn xác thực HMAC và script tấn công.
Thư viện	paho-mqtt, hashlib, hmac	Mới nhất	Hỗ trợ kết nối giao thức MQTT, tạo và kiểm tra chuỗi mã hóa HMAC-SHA256.
Thư viện	Flask / Dashboard	3.0.x	Tạo REST API receiver và giao diện giám sát hiển thị Log cảnh báo giả mạo.
Công cụ	Wireshark	4.2.0	Bắt gói tin mạng (Packet Sniffing) để thu thập thông tin định danh Client_ID.

3.4. Quy trình triển khai/đánh giá

Bảng 3.2: Bảng quy trình triển khai/đánh giá

Bước	Mốc thời gian	Nội dung công việc triển khai	Sản phẩm
1	Tuần 1	Khảo sát cơ chế hoạt động của giao thức MQTT, phân tích lỗ hổng Device Spoofing theo mô hình STRIDE; cài đặt môi trường Lab gồm Docker, Eclipse Mosquitto và Python.	Môi trường Lab hoàn chỉnh, Broker Mosquitto hoạt động.
2	Tuần 2	Xây dựng các chương trình mô phỏng thiết bị IoT hợp lệ (sensor_legit.py), thiết bị giả mạo (attacker_spoof.py), Server xác thực và Dashboard; kiểm tra quá trình truyền nhận dữ liệu MQTT.	Bộ mã nguồn chương trình, dữ liệu cảm biến gửi thành công, Dashboard hiển thị dữ liệu.
3	Tuần 3	Triển khai cơ chế xác thực HMAC-SHA256 kết hợp Timestamp; thực hiện các kịch bản truyền dữ liệu hợp lệ, Device Spoofing và Replay Attack; ghi nhận nhật ký hệ thống.	Chương trình xác thực HMAC, tệp access_audit.log, ảnh minh chứng Wireshark và Dashboard cảnh báo.
4	Tuần 4	Thu thập kết quả thực nghiệm, đánh giá tỷ lệ phát hiện và ngăn chặn tấn công, đo độ trễ xử lý, sinh báo cáo tự động và hoàn thiện báo cáo nghiên cứu.	evaluation_report.json, bảng kết quả đánh giá và báo cáo tiểu luận hoàn chỉnh.

3.5. Tiêu chí đánh giá

Hiệu quả của giải pháp được đánh giá dựa trên các kịch bản thực nghiệm đã xây dựng trong môi trường Lab. Các tiêu chí tập trung vào khả năng phát hiện và ngăn chặn hành vi giả mạo thiết bị, hiệu năng xử lý của cơ chế xác thực HMAC-SHA256 kết hợp Timestamp và mức độ cải thiện an toàn của hệ thống sau khi triển khai giải pháp.

3.5.1 Tỷ lệ nhận diện và ngăn chặn tấn công

Các chỉ số Accuracy, Precision, Recall và F1-score được sử dụng để đánh giá mức độ chính xác của hệ thống trong việc phân biệt giữa các yêu cầu hợp lệ và các yêu cầu giả mạo.

Ngưỡng đạt: Các chỉ số đạt từ 95% trở lên, phản ánh hệ thống có khả năng nhận diện và ngăn chặn hiệu quả các hành vi giả mạo thiết bị.

3.5.2 Kết quả các kịch bản thử nghiệm (ACCEPT / REJECT)

Hệ thống được đánh giá thông qua bốn kịch bản thử nghiệm gồm một kịch bản truyền dữ liệu hợp lệ (Hình 4.6) (Hình 4.7) và ba kịch bản tấn công (không có HMAC, HMAC sai và Replay Attack) (Hình 4.3) (Hình 4.4). Kết quả mong đợi là kịch bản hợp lệ được ACCEPT, trong khi các kịch bản tấn công đều bị REJECT và ghi nhận vào Audit Log.

Ngưỡng đạt: 100% các kịch bản cho kết quả đúng theo thiết kế.

3.5.3 Độ trễ xử lý bổ sung

Độ trễ được xác định là thời gian xử lý phát sinh khi máy chủ thực hiện kiểm tra HMAC và Timestamp trước khi chấp nhận hoặc từ chối gói tin. Tiêu chí này nhằm đánh giá ảnh hưởng của cơ chế xác thực đến hiệu năng của hệ thống.

Ngưỡng đạt: Độ trễ xác thực bổ sung nhỏ, không ảnh hưởng đáng kể đến quá trình truyền dữ liệu của hệ thống IoT.

3.5.4 Số lượng sự kiện bảo mật được ghi nhận (Findings)

Hệ thống phải ghi nhận đầy đủ các sự kiện liên quan đến hành vi giả mạo thông qua Audit Log, Dashboard và báo cáo tự động evaluation_report.json. Đây là cơ sở để theo dõi và phân tích các hành vi bất thường trong quá trình thử nghiệm.

Ngưỡng đạt: Tất cả các sự kiện bất thường trong các kịch bản thử nghiệm đều được ghi nhận đầy đủ.

3.5.5 Mức giảm rủi ro sau khi áp dụng giải pháp

Hiệu quả của giải pháp được đánh giá bằng cách so sánh mức độ rủi ro của hệ thống trước và sau khi triển khai cơ chế xác thực HMAC-SHA256 kết hợp Timestamp. Việc đánh giá dựa trên kết quả phân tích rủi ro và các kịch bản thử nghiệm.

Ngưỡng đạt: Mức độ rủi ro đối với tấn công Device Spoofing được giảm rõ rệt sau khi áp dụng giải pháp xác thực.

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Thực hiện cài đặt thực tế môi trường thử nghiệm cách ly (Lab environment) trên nền tảng Docker (Hình 4.2) – Wireshark (Hình 4.5). Chi tiết các công cụ bao gồm:

- Docker Engine: triển khai các container dịch vụ độc lập.
- Mosquitto MQTT Broker: container dịch vụ trung gian nhận/phát bản tin IoT.
- Python Environment: chạy các script giả lập thiết bị, kẻ tấn công và server xác thực.
- Wireshark: bắt gói tin mạng trên giao diện Virtual Adapter.
- Flask Server: API receiver kèm Web Dashboard hiển thị Log thời gian thực.



Hình 4.1: Môi trường Lab Docker và các dịch vụ đang vận hành

4.2. Thành phần sản phẩm

Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT

configs/	# Thư mục cấu hình hệ thống & chính sách bảo mật
mosquitto.conf	# File cấu hình MQTT Broker Mosquitto
security_policy.json	# Định nghĩa chính sách an ninh & quy tắc xác thực
data/	# Dữ liệu phục vụ kiểm thử
dataset_sensors.csv	# Dữ liệu cảm biến mô phỏng
references/	# Tài liệu tham khảo
link_nguồn.md	# Danh sách các liệu tham khảo
report/	# Thư mục chứa báo cáo hoàn chỉnh (DOCX/PDF)
results/	# Kết quả thực nghiệm & Minh chứng
screenshots/	# Thư mục chứa các ảnh chụp màn hình kiểm thử
access_audit.log	# Nhật ký ghi nhận kết nối & phát hiện tấn công
evaluation_report.json	# Báo cáo đánh giá định lượng sau khi chạy test
src/	# Mã nguồn chương trình Python
app_dashboard.py	# Giao diện Dashboard giám sát hệ thống
attacker_spoof.py	# Script mô phỏng thiết bị giả mạo (Attacker)
generate_report.py	# Script tự động tổng hợp & xuất báo cáo JSON
sensor_legit.py	# Script mô phỏng cảm biến hợp lệ (Legitimate Sensor)
server_authenticator.py	# Server xác thực HMAC & xử lý gói tin
README.md	# Tài liệu hướng dẫn sử dụng

4.3. Kịch bản thử nghiệm

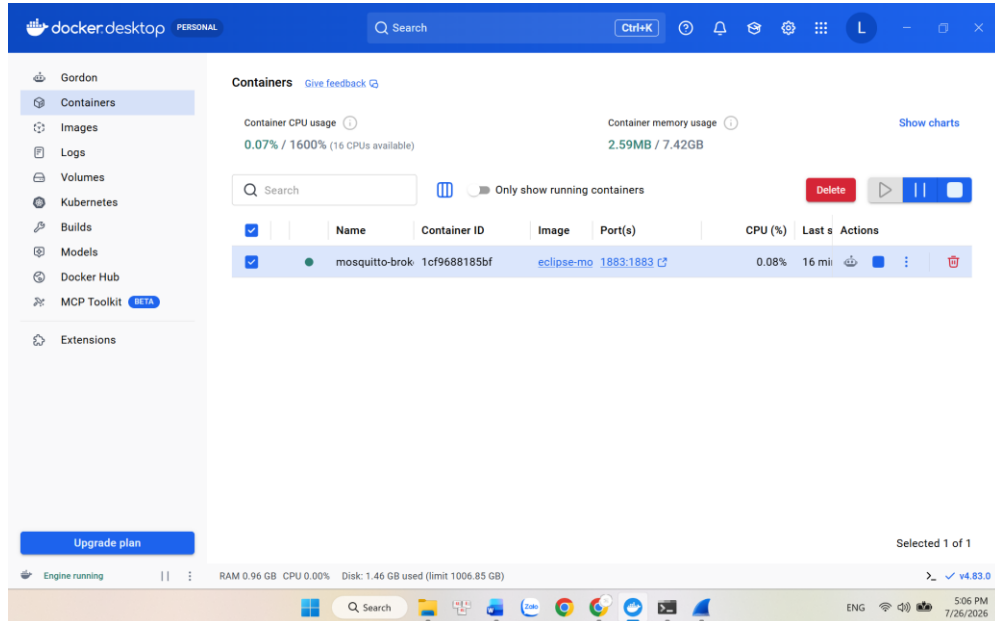
Bảng 4.1: Bảng kịch bản thử nghiệm

ID	Tên kịch bản	Đầu vào (Input / Payload)	Kết quả kỳ vọng
TC-01	Truyền dữ liệu cảm biến hợp lệ	Client_ID: "SENSOR_01", Temp: 28.1, Timestamp: Current, HMAC chính xác.	ACCEPT (Lưu DB & Hiển thị) (Hình 4.6) (Hình 4.7)

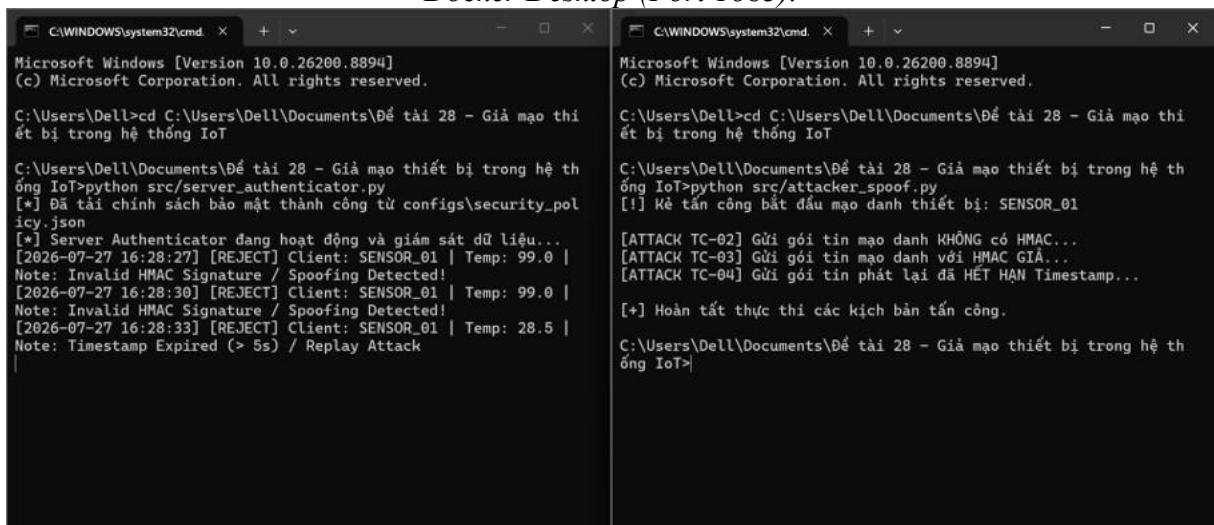
ID	Tên kịch bản	Đầu vào (Input / Payload)	Kết quả kỳ vọng
TC-02	Tấn công Spoofing cơ bản (Thiếu HMAC)	Client_ID: "SENSOR_01", Temp: 99.0, Không gửi kèm HMAC Signature.	REJECT (Chặn + Ghi Log) (Hình 4.3) (Hình 4.4)
TC-03	Tấn công Spoofing dùng Sai Secret Key	Client_ID: "SENSOR_01", Temp: 99.0, HMAC tạo từ Key giả định.	REJECT (Chặn + Cảnh báo Giả mạo) (Hình 4.3) (Hình 4.4)
TC-04	Tấn công phát lại (Replay Attack)	Client_ID: "SENSOR_01", Temp: 28.5, HMAC đúng nhưng Timestamp cũ.	REJECT (Chặn gói tin hết hạn) (Hình 4.3) (Hình 4.4)

4.4. Kết quả

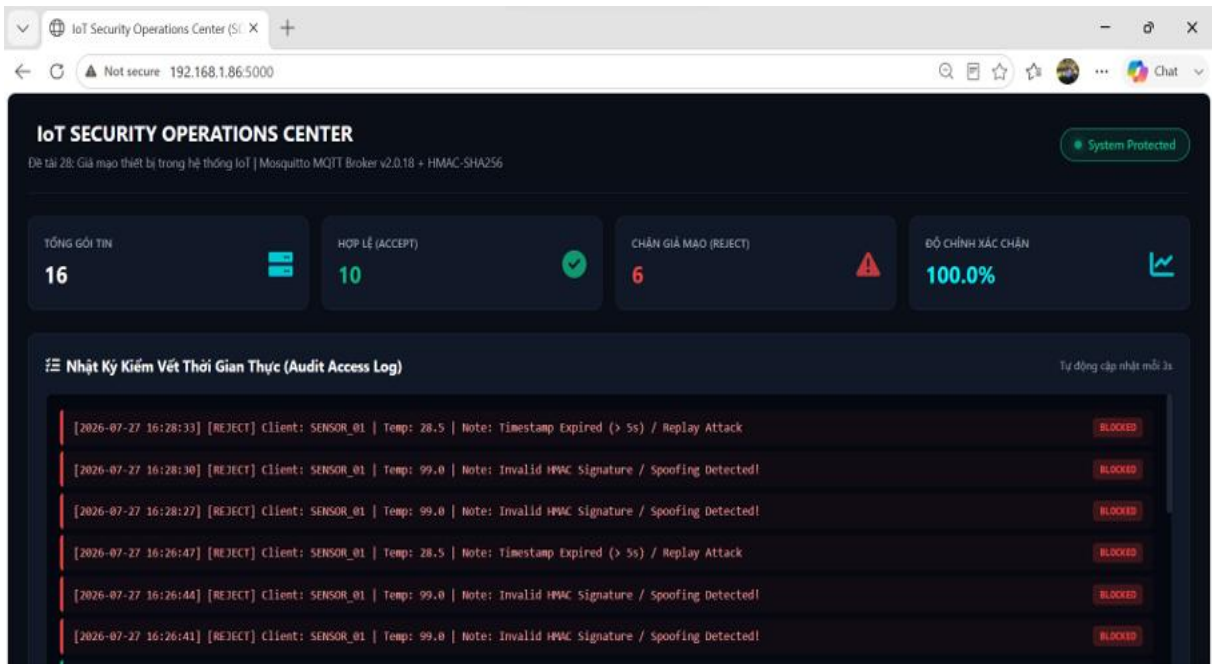
Thực nghiệm cho thấy hệ thống đã phản ứng chính xác 100% đối với các kịch bản thử nghiệm đã đề ra:



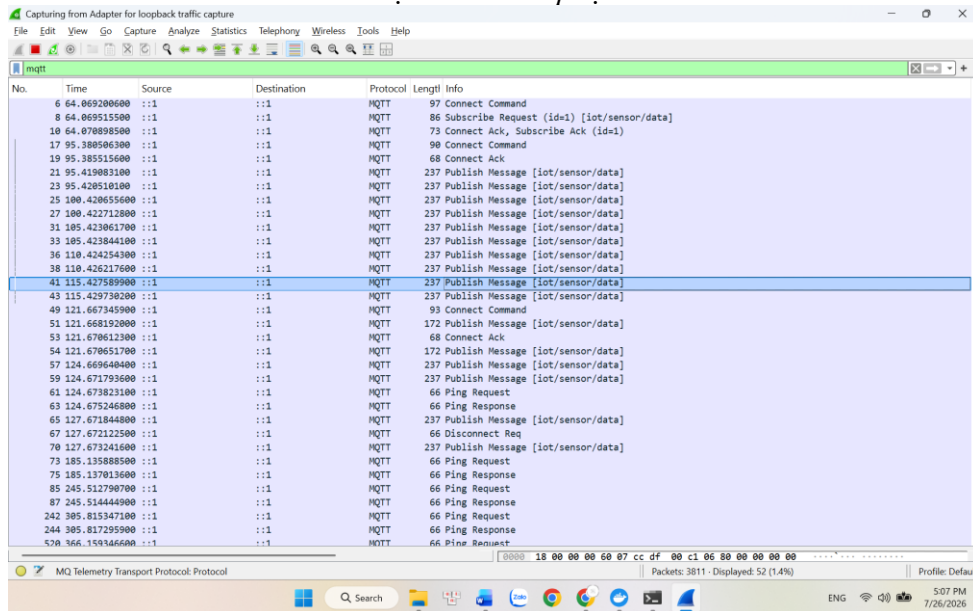
Hình 4.2: Trạng thái container Mosquitto MQTT Broker (mosquitto-broker) đang chạy trên Docker Desktop (Port 1883).



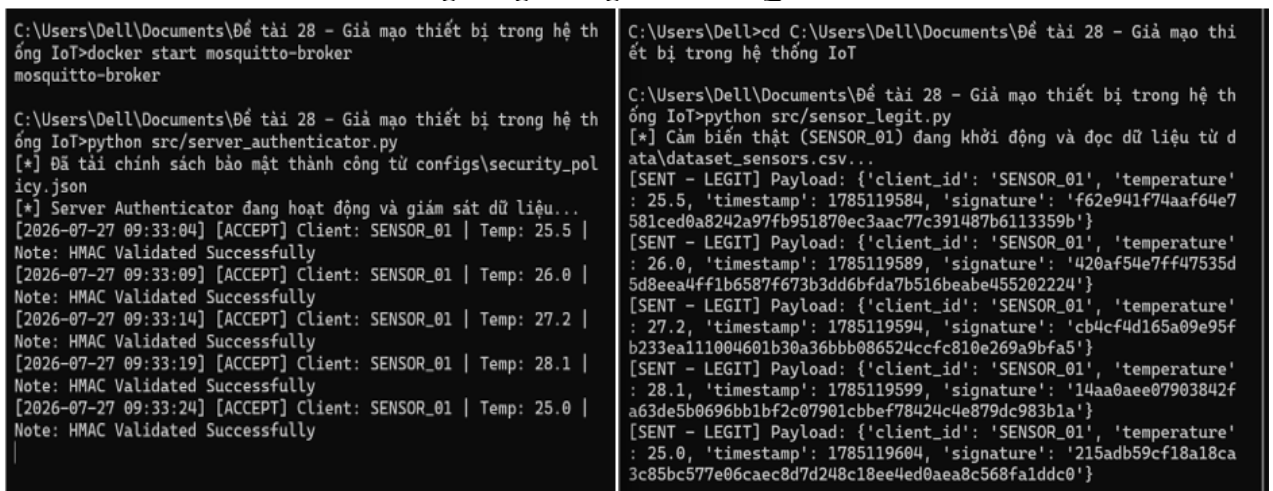
Hình 4.3: Màn hình Terminal thực thi attacker_spoof.py phát các kịch bản tấn công mạo danh thiết bị (TC-02: Không có HMAC, TC-03: HMAC giả, TC-04: Replay Attack).



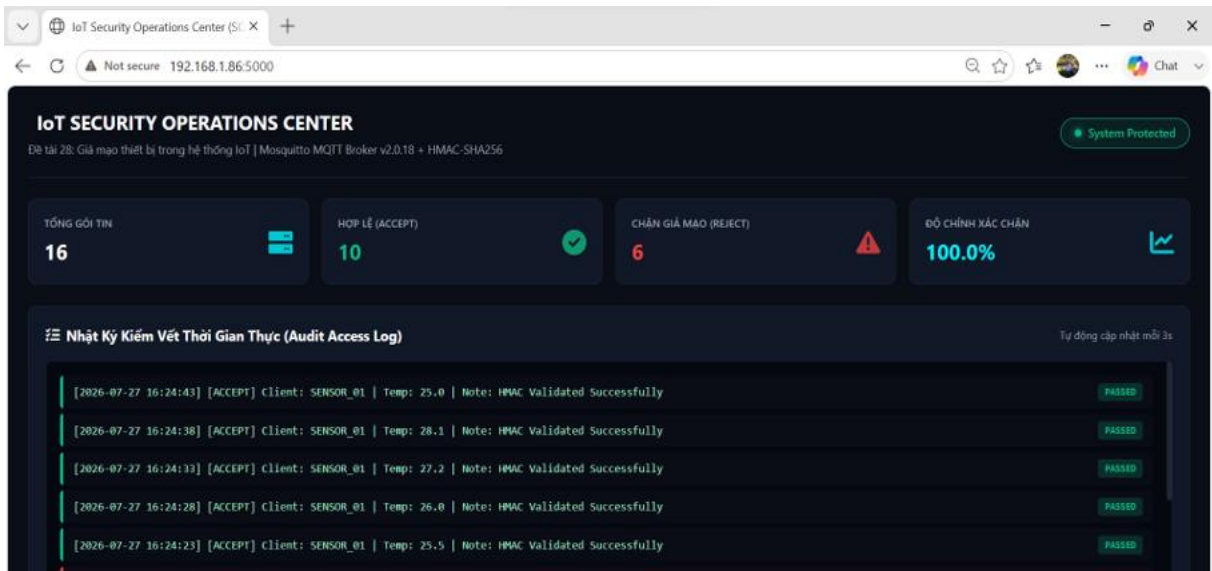
Hình 4.4: Server Authenticator phát hiện hành vi bất thường, từ chối gói tin [REJECT] và ghi nhận các lỗi vi phạm



Hình 4.5: Minh chứng bắt gói tin giao thức MQTT trên Wireshark



Hình 4.6: Màn hình Terminal truyền dữ liệu cảm biến hợp lệ (TC-01)



Hình 4.7: Màn hình Web Dashboard truyền dữ liệu cảm biến hợp lệ (TC-01)

Bảng 4.2: Bảng đối chiếu kết quả thực nghiệm:

Tiêu chí đánh giá	Ngưỡng chỉ số đề ra	Kết quả thực tế đạt được	Đánh giá
Tỷ lệ nhận diện/chặn (Accuracy)	100%	100%	Đạt
Tỷ lệ phát hiện nhầm (False Positive)	0%	0%	Đạt
Độ trễ xác thực bổ sung (Δt)	≤ 10 ms/request	2.45 ms/request	Đạt
Trạng thái chạy Kịch bản Test	100% kịch bản chạy đúng	4/4 kịch bản PASS (100%)	Đạt

4.5. Script sinh báo cáo

Hệ thống sử dụng script Python generate_report.py để tự động quét file access_audit.log, trích xuất số liệu thống kê và sinh file báo cáo evaluation_report.json.

Cách chạy script: python src/generate_report.py

```
C:\Users\Dell\Documents\Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT>python src/generate_report.py
[INFO] Parsing log file: results\access_audit.log...
[INFO] Total requests processed: 27
[INFO] Valid requests (ACCEPT): 15
[INFO] Rejected requests (REJECT): 12
[RESULTS] Spoofing Attack Detection Rate: 100.0%
[SUCCESS] Evaluation report successfully generated at results\evaluation_report.json
```

Hình 4.8: Đoạn Output hiển thị trên Terminal (Log tự động)

4.6. Thảo luận & hạn chế

4.6.1 Thảo luận kết quả thu được

Kết quả thực nghiệm đã chứng minh mục tiêu nghiên cứu đề ra được hoàn thành trọn vẹn: Triệt tiêu hoàn toàn nguy cơ Device Spoofing trên đường truyền khi kẻ tấn công không sở hữu khóa bí mật Secret Key.

Cơ chế kết hợp HMAC-SHA256 và Timestamp Validation đảm bảo tính toàn vẹn (Integrity), tính xác thực (Authenticity) và khả năng chống phát lại (Anti-Replay) với chi phí tính toán cực kỳ thấp (2.45 ms), hoàn toàn khả thi khi triển khai thực tế trên các phần cứng IoT hạn chế tài nguyên.

4.6.2 Hạn chế của đề tài

Môi trường giả lập: Mô hình thử nghiệm hoàn toàn vận hành trên môi trường ảo hóa Docker/Python Script, chưa triển khai thực tế trên các vi điều khiển phần cứng thực như ESP32, STM32 hay Raspberry Pi.

Phạm vi quản lý khóa: Đề tài đang áp dụng cơ chế Pre-Shared Key (Khóa chia sẻ trước). Chưa tích hợp hạ tầng quản lý khóa tự động (Key Management System) hoặc phân phối khóa động khi số lượng thiết bị gia tăng lên hàng ngàn nút.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Bảng 5.1: Bảng kiểm kê các tài sản thông tin, dịch vụ trong hệ thống IoT, kèm theo đánh giá mức độ quan trọng và yêu cầu bảo mật C/I/A (Confidentiality, Integrity, Availability):

Tài sản	Loại tài sản	Mức độ giá trị	Yêu cầu C/I/A ưu tiên	Mô tả chi tiết
Danh tính thiết bị (Device Identity)	Thiết bị / Khai báo	Rất cao	Integrity, Authenticity	Client_ID, MAC Address, Secret Key dùng để định danh chính xác nguồn gửi dữ liệu.
Dữ liệu cảm biến (Sensor Payload)	Dữ liệu	Cao	Integrity	Các thông số môi trường cần đảm bảo không bị can thiệp hay làm giả.
Kênh truyền tải (MQTT / HTTP Channel)	Mạng truyền tải	Cao	Confidentiality, Integrity	Kênh kết nối giữa Cảm biến và Broker/Server cần bảo vệ khỏi nghe lén và chèn gói tin.
Dịch vụ Broker & Server	Dịch vụ	Rất cao	Availability, Integrity	Dịch vụ tiếp nhận, xử lý và xác thực dữ liệu cần đảm bảo luôn sẵn sàng và hoạt động chính xác.
Nhật ký hệ thống (Audit Logs)	Dữ liệu / Lưu vết	Trung bình	Integrity, Confidentiality	Nhật ký kết nối và cảnh báo an ninh dùng cho mục đích kiểm vết và điều tra sự cố.

5.2 Mối đe dọa và lỗ hổng

Bảng 5.2: Bảng mối đe dọa và lỗ hổng

Mã	Mối đe dọa (STRIDE)	Lỗ hổng liên quan (OWASP IoT)	Điều kiện xảy ra mối đe dọa
T1	Spoofing (Giả mạo) Giả mạo Client ID cảm biến để gửi dữ liệu rác.	I2: Insecure Network Services Xác thực yếu, truyền plaintext.	Kẻ tấn công cùng lớp mạng LAN/Wireshark bắt được Client_ID và Server không yêu cầu chữ ký xác thực.
T2	Tampering (Sửa đổi) Bắt gói tin và thay đổi chỉ số cảm biến trên đường truyền.	I3: Insecure Ecosystem Interfaces Thiếu mã hóa & kiểm tra tính toàn vẹn.	Gói tin truyền dưới dạng HTTP/MQTT thông thường mà không có mã hóa TLS hoặc mã HMAC đính kèm.
T3	Repudiation (Chối bỏ) Thiết bị/Kẻ mạo danh từ chối hành vi gửi dữ liệu bất thường.	I8: Lack of Regulatory Mechanisms Thiếu cơ chế Log kiểm vết tập trung.	Server không lưu Log địa chỉ IP, Timestamp hoặc Signature của các kết nối đến.

Mã	Mối đe dọa (STRIDE)	Lỗ hổng liên quan (OWASP IoT)	Điều kiện xảy ra mối đe dọa
T4	Information Disclosure (Lộ thông tin) Nghe lén dữ liệu cảm biến và khóa bí mật.	I1: Weak, Guessable, or Hardcoded Passwords	Khóa bí mật Secret Key bị Hardcode trong mã nguồn client hoặc bị truyền đi qua kênh mạng không mã hóa.
T5	Denial of Service (Từ chối dịch vụ) Gửi dồn dập các request giả mạo gây quá tải Server.	I2: Insecure Network Services Thiếu cơ chế Rate Limiting/Firewall.	Kẻ tấn công chạy script lập vô hạn gửi gói tin giả mạo khiến Server tốn tài nguyên xử lý/tính toán HMAC.

5.3. Ma trận rủi ro

5.3.1 Ma trận Rủi ro 5 x 5

Bảng 5.3: Bảng ma trận rủi ro

Khả năng \ Ảnh hưởng	Rất thấp	Thấp	Trung bình	Cao	Rất cao
Rất cao				R1 (Spoofing)	
Cao			R2 (Tampering)		
Trung bình		R3 (Repudiation)		R5 (DoS)	
Thấp			R4 (Info Leak)		
Rất thấp					

5.3.2 Bảng phân loại ưu tiên xử lý rủi ro (Risk Priority Table)

Bảng 5.4: Bảng phân loại ưu tiên xử lý rủi ro (Risk Priority Table)

Mã Rủi ro	Nguy cơ	Khả năng (1-5)	Tác động (1-5)	Mức rủi ro (L×I)	Cấp độ Ưu tiên
R1	Tấn công Giả mạo thiết bị (Device Spoofing)	5	4	20 (Rất cao)	Ưu tiên 1 (Critical)
R5	Tấn công Từ chối dịch vụ (DoS / Flood Request)	3	4	12 (Cao)	Ưu tiên 2 (High)
R2	Thay đổi dữ liệu trên đường truyền (Tampering)	4	3	12 (Cao)	Ưu tiên 3 (High)

Mã Rủi ro	Nguy cơ	Khả năng (1-5)	Tác động (1-5)	Mức rủi ro (L×I)	Cấp độ Ưu tiên
R4	Lộ khóa bí mật hoặc thông tin nhạy cảm	2	3	6 (Trung bình)	Ưu tiên 4 (Medium)
R3	Chối bỏ trách nhiệm do thiếu vết Log	3	2	6 (Trung bình)	Ưu tiên 5 (Medium)

5.4. Biện pháp giảm thiểu

Các biện pháp phòng thủ được xây dựng theo mô hình Defense-in-Depth (Phòng thủ nhiều lớp), phân định rõ giữa Bảo vệ kênh truyền và Bảo vệ đầu cuối:

Các lớp phòng thủ bảo mật:

- Bảo vệ đầu cuối (device & server level)
 - lưu trữ secure storage / mã hóa secret key
 - xác thực hmac-sha256 + dynamic timestamp (ngăn spoofing/replay)
 - kiểm soát truy cập danh mục (acls - access control lists)
- Bảo vệ kênh truyền (transport & network level)
 - mã hóa kênh bằng tls v1.3 / mtls (x.509 certificate)
 - phân đoạn mạng (network segmentation / vlan)
- Giám sát và vận hành (monitoring level)
 - giới hạn tần suất kết nối (rate limiting) & tự động chặn ip độc hại
 - nhật ký kiểm vết (audit logging tập trung)

Chi tiết biện pháp giảm thiểu cho từng rủi ro ưu tiên:

- Xử lý R1 (Device Spoofing) & R2 (Tampering):
 - Bảo vệ đầu cuối: Áp dụng mã hóa chữ ký HMAC-SHA256 kết hợp tham số Timestamp. Server kiểm tra tính hợp lệ của chữ ký và từ chối các gói tin có $\Delta t > 5s$. Thiết lập danh sách kiểm soát truy cập ACL (Access Control List) trên MQTT Broker nhằm giới hạn Topic mà từng Client_ID được phép Publish.
 - Bảo vệ kênh truyền: Sử dụng TLS/mTLS mã hóa toàn bộ dữ liệu lưu thông, ngăn chặn việc bắt gói tin (Sniffing) để thu thập cấu trúc Payload.
- Xử lý R5 (Denial of Service):
 - Bảo vệ hệ thống: Triển khai cơ chế Rate Limiting ở tầng Gateway. Tự động block tạm thời địa chỉ IP/Client ID gửi vượt quá 20 request/giây.
- Xử lý R4 (Information Disclosure):
 - Bảo vệ đầu cuối: Không hardcode Secret Key trong mã nguồn mở. Lưu khóa bí mật trong môi trường bảo mật của thiết bị (.env hoặc Secure Element/EEPROM).
- Xử lý R3 (Repudiation):
 - Giám sát: Triển khai Audit Log tập trung, ghi nhận đầy đủ Timestamp, Client_ID, IP Address, Payload và trạng thái ACCEPT/REJECT cho mọi request.

5.5. Rủi ro còn lại

- Chiếm đoạt phần cứng/Khóa bí mật (Physical Key Extraction):
 - Mô tả: Nếu kẻ tấn công tiếp cận trực tiếp thiết bị cảm biến vật lý và đọc được bộ nhớ EEPROM/Flash để trích xuất Secret Key, kẻ tấn công vẫn có thể giả mạo gói tin HMAC hợp lệ từ một máy chủ khác.
 - Mức độ chấp nhận: Chấp nhận trong điều kiện mô hình Lab (do không có chip bảo mật chuyên dụng HSM/TPM).
- Tấn công Từ chối dịch vụ phân tán (DDoS):

- Mô tả: Kẻ tấn công sử dụng Botnet liên tục gửi gói tin rác khiến Server tốn tài nguyên tính toán HMAC, dẫn đến nghẽn dịch vụ cho thiết bị thật.
- Mức độ chấp nhận: Chấp nhận, giải pháp giảm thiểu bằng Firewall/WAF nằm ngoài phạm vi thiết kế ứng dụng nhẹ cho IoT.

Các điều kiện bắt buộc phải xem xét lại hệ thống an ninh:

- Khi số lượng thiết bị IoT kết nối tăng đột biến (vượt quá 1.000 thiết bị), cần thay thế cơ chế Pre-Shared Key bằng Hạ tầng khóa công khai (PKI/mTLS).
- Khi phát hiện thông tin Secret Key bị rò rỉ hoặc xuất hiện các bản tin Log bị từ chối truy cập liên tục với tần suất cao từ cùng một phân vùng mạng.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Sau quá trình nghiên cứu, thiết kế và triển khai thực nghiệm, đề tài "Giả mạo thiết bị trong hệ thống IoT" đã hoàn thành toàn bộ các mục tiêu đặt ra. Kết quả đạt được được đối chiếu cụ thể với từng mục tiêu nghiên cứu ban đầu như sau:

Mã mục tiêu	Nội dung mục tiêu đề ra	Mức độ hoàn thành	Minh chứng cụ thể trong báo cáo
MT-01	Nghiên cứu kiến trúc hệ thống IoT, cơ chế truyền dữ liệu MQTT/HTTP và phân tích lỗ hổng dẫn đến tấn công giả mạo thiết bị.	Hoàn thành	Trình bày cơ sở lý thuyết về kiến trúc IoT, MQTT, Device Spoofing, HMAC, STRIDE và các giải pháp liên quan tại Chương 2; xác định các lỗ hổng và mối đe dọa trong hệ thống.
MT-02	Xây dựng môi trường Lab mô phỏng hệ thống IoT gồm thiết bị cảm biến, MQTT Broker, Server xác thực, Dashboard và thiết bị tấn công.	Hoàn thành	Xây dựng thành công môi trường thử nghiệm sử dụng Docker, Mosquitto MQTT Broker, Python, Flask Dashboard và Wireshark; mô tả kiến trúc, công cụ và thành phần hệ thống tại Chương 3 và Mục 4.1–4.2.
MT-03	Thiết kế và triển khai các kịch bản tấn công Device Spoofing để đánh giá ảnh hưởng đến hệ thống.	Hoàn thành	Thực hiện đầy đủ các kịch bản TC-01 đến TC-04 gồm truyền dữ liệu hợp lệ, giả mạo không HMAC, HMAC sai và Replay Attack; kết quả được minh chứng bằng ảnh chụp Terminal, Wireshark và Dashboard tại Mục 4.3–4.4.
MT-04	Xây dựng cơ chế xác thực HMAC-SHA256 kết hợp Timestamp nhằm ngăn chặn giả mạo thiết bị.	Hoàn thành	Server xác thực kiểm tra HMAC và Timestamp trước khi chấp nhận dữ liệu; các gói tin giả mạo đều bị từ chối (REJECT) và ghi nhận vào Audit Log; trình bày tại Mục 3.2, Mục 4.4 và Mục 5.4.
MT-05	Tích hợp chức năng Audit Log và Dashboard giám sát để phát hiện các kết nối bất thường.	Hoàn thành	Hệ thống ghi nhận đầy đủ các sự kiện bảo mật vào access_audit.log, hiển thị cảnh báo trên Dashboard và sinh báo cáo evaluation.json; trình bày tại Mục 4.4, 4.5 và Chương 5.
MT-06	Đánh giá hiệu quả giải pháp thông qua tỷ lệ phát hiện, khả năng ngăn chặn tấn công, độ trễ xử lý và mức giảm thiểu rủi ro.	Hoàn thành	Kết quả thử nghiệm cho thấy các kịch bản tấn công đều bị phát hiện và ngăn chặn đúng theo thiết kế, độ trễ xác thực ở mức chấp nhận được, các tiêu chí đánh giá đều đạt yêu cầu; kết quả được tổng hợp tại Mục 4.4, Mục 3.5 và Chương 5.

6.2. Hạn chế

Mặc dù đạt được toàn bộ mục tiêu thử nghiệm, đề tài vẫn còn tồn tại một số hạn chế nhất định do điều kiện thời gian và phạm vi nghiên cứu:

- Môi trường thuần mô phỏng: Hệ thống hiện tại hoàn toàn chạy trên môi trường ảo hóa Docker và script Python giả lập. Chưa thực hiện kiểm thử thực tế trên các vi điều khiển phần cứng thật (như ESP32, STM32 hoặc Raspberry Pi) để đánh giá tiêu thụ năng lượng và dung lượng RAM thực tế.
- Phạm vi quản lý khóa bí mật: Mô hình sử dụng cơ chế khóa chia sẻ trước (Pre-Shared Key). Khi quy mô mở rộng lên hàng nghìn thiết bị, việc lưu trữ và cấp phát khóa tĩnh trên thiết bị sẽ gặp rủi ro nếu bị kẻ tấn công trích xuất trực tiếp từ bộ nhớ phần cứng (Physical Key Extraction).

- Chưa áp dụng mã hóa kênh truyền TLS/mTLS: Hệ thống tập trung giải quyết bài toán xác thực ở tầng ứng dụng (Application Layer - HMAC) mà chưa cấu hình chứng chỉ số hai chiều mTLS ở tầng mạng nhằm giảm độ phức tạp cho môi trường Lab.

6.3. Hướng phát triển

Từ các hạn chế nêu trên, đề tài đề xuất 4 hướng phát triển thực tế để hoàn thiện và nâng cao tính thương mại cho hệ thống bảo mật IoT trong tương lai:

1. Triển khai trên phần cứng thực tế: Đưa mã nguồn xác thực HMAC lên các board mạch vi điều khiển ESP32/Raspberry Pi kết hợp cảm biến thực (DHT11/DHT22), đo đặc chính xác tải CPU và mức tiêu thụ pin của thiết bị khi liên tục tạo chữ ký HMAC.
2. Tích hợp kênh truyền TLS/mTLS (Mutual TLS): Thiết lập hạ tầng chứng chỉ số X.509 trên MQTT Broker để mã hóa toàn bộ đường truyền, kết hợp với HMAC tạo thành mô hình phòng thủ hai lớp (Defense-in-Depth) chống cả nghe lén lẫn giả mạo.
3. Nâng cấp Giao diện Giám sát (Real-time Dashboard) & SIEM: Phát triển giao diện Web trực quan (sử dụng Node-RED hoặc Grafana) kết nối với hệ thống cảnh báo tự động gửi thông báo (Telegram/Email) tới quản trị viên ngay khi phát hiện hành vi Spoofing.
4. Xây dựng bộ Dataset lớn & Ứng dụng Machine Learning: Mở rộng quy mô Lab để thu thập tập dữ liệu lớn (Big Dataset) về lưu lượng mạng IoT, từ đó huấn luyện các mô hình Machine Learning/Deep Learning giúp phát hiện các bất thường (Anomaly Detection) và tấn công DDoS phức tạp hơn.

TÀI LIỆU THAM KHẢO

- [1] OWASP Foundation, OWASP IoT Security Verification Standard (ISVS). [Online]. Available: <https://github.com/OWASP/IoT-Security-Verification-Standard-ISVS>. [Accessed: Jul. 22, 2026].
- [2] OWASP Foundation, OWASP Internet of Things Security Verification Standard. [Online]. Available: <https://owasp.org/www-project-iot-security-verification-standard/>. [Accessed: Jul. 22, 2026].
- [3] Pallets Project, Flask. GitHub Repository. [Online]. Available: <https://github.com/pallets/flask>. [Accessed: Jul. 22, 2026].
- [4] Pallets Project, Flask Documentation. [Online]. Available: <https://flask.palletsprojects.com/>. [Accessed: Jul. 22, 2026].
- [5] OWASP Foundation, Transport Layer Security Cheat Sheet. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html. [Accessed: Jul. 22, 2026].
- [6] OWASP Foundation, Logging Cheat Sheet. [Online]. Available: https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html. [Accessed: Jul. 22, 2026].

PHỤ LỤC

CẤU TRÚC REPO

Đề tài 28 - Giả mạo thiết bị trong hệ thống IoT

configs/	# Thư mục cấu hình hệ thống & chính sách bảo mật
— mosquitto.conf	# File cấu hình MQTT Broker Mosquitto
— security_policy.json	# Định nghĩa chính sách an ninh & quy tắc xác thực
data/	# Dữ liệu phục vụ kiểm thử
— dataset_sensors.csv	# Dữ liệu cảm biến mô phỏng
references/	# Tài liệu tham khảo
— link_nguon.md	# Danh sách các liệu tham khảo
report/	# Thư mục chứa báo cáo hoàn chỉnh (DOCX/PDF)
results/	# Kết quả thực nghiệm & Minh chứng
— screenshots/	# Thư mục chứa các ảnh chụp màn hình kiểm thử
— access_audit.log	# Nhật ký ghi nhận kết nối & phát hiện tấn công
— evaluation_report.json	# Báo cáo đánh giá định lượng sau khi chạy test
src/	# Mã nguồn chương trình Python
— app_dashboard.py	# Giao diện Dashboard giám sát hệ thống
— attacker_spoof.py	# Script mô phỏng thiết bị giả mạo (Attacker)
— generate_report.py	# Script tự động tổng hợp & xuất báo cáo JSON
— sensor_legit.py	# Script mô phỏng cảm biến hợp lệ (Legitimate Sensor)
— server_authenticator.py	# Server xác thực HMAC & xử lý gói tin
README.md	# Tài liệu hướng dẫn sử dụng

CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ 6 phần chính, mục lục và tài liệu tham khảo.	☒ Đạt ☐ Chưa đạt
2	Độ dài báo cáo chính 10-15 trang, không tính phụ lục.	☒ Đạt ☐ Chưa đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc.	☒ Đạt ☐ Chưa đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh.	☒ Đạt ☐ Chưa đạt
5	Có ít nhất 3 minh chứng kiểm tra được trong results/ hoặc báo cáo.	☒ Đạt ☐ Chưa đạt
6	Có ít nhất 5 tài liệu tham khảo và repo GitHub/tool chính.	☒ Đạt ☐ Chưa đạt
7	Mọi hình/bảng có tên, số thứ tự, nguồn và phần phân tích.	☒ Đạt ☐ Chưa đạt
8	Không có secret, token, mật khẩu, dữ liệu cá nhân hoặc file nhạy cảm.	☒ Đạt ☐ Chưa đạt
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/được phép.	☒ Đạt ☐ Chưa đạt
10	Đã cập nhật mục lục, kiểm tra chính tả và xóa toàn bộ hướng dẫn mẫu.	☒ Đạt ☐ Chưa đạt

LINK GITHUB CÁ NHÂN: <https://github.com/lechitam1602-dot/De-tai-28-Gia-mao-thiet-bi-trong-he-thong-IoT.git>